ĐHQG-HCM — TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN
KHOA CÔNG NGHỆ THÔNG TIN

Hệ điều hành Linux & Ứng dụng

ĐỒ ÁN THỰC HÀNH

1. Quy định chung

1.1 Môi trường

Trình ảo hóa: Oracle VirtualBox hoặc VMware Workstation/Player (chọn một; ghi lại trong báo cáo).

Hệ điều hành khách: Ubuntu 22.04 LTS Server HOẶC CentOS Stream 9 (nên dùng bản không giao diện đồ họa để gọn nhẹ).

1.2 Quy mô nhóm & phân công

Mỗi nhóm gồm 5 sinh viên.

- Có bảng phân công công việc trong báo cáo, ánh xạ 5 thành viên lên ba thành phần của dự án (Mục 3, 4, 5). Gợi ý 5 vai: (1) hạ tầng & mạng, (2) reverse proxy & bảo mật web, (3) ứng dụng & systemd, (4) CSDL & sao lưu, (5) bộ công cụ tự động hóa & cảnh báo.
- Điểm chấm theo cá nhân trên nền điểm nhóm: mỗi thành viên phải bảo vệ được phần mình phụ trách VÀ hiểu tổng thể hệ thống. Thành viên không giải thích được phần của mình sẽ bị trừ điểm cá nhân dù hệ thống chạy tốt.
- Trong buổi vấn đáp, giảng viên có thể hỏi bất kỳ thành viên nào về bất kỳ thành phần nào của hệ thống.

1.3 Sản phẩm nộp

Một file nén đặt tên theo mẫu

```
MSSV1_MSSV2_….tar.gz
```

bao gồm:

- Báo cáo kỹ thuật (PDF).
- Toàn bộ script Bash nhóm viết, giữ nguyên shebang và chú thích.
- Toàn bộ file cấu hình dịch vụ đã chỉnh (Nginx/Apache, systemd unit, cấu hình CSDL, luật UFW/firewalld, fail2ban, auditd) — file thật, không phải ảnh chụp.
- Một file README.md nêu: hướng đồ án đã chọn, sơ đồ VM, bảng phân công thành viên, và cách tái tạo hệ thống.

2. Nền tảng bắt buộc

Hệ thống của nhóm phải thỏa toàn bộ các yêu cầu sau.

2.1 Hệ thống

- Cài Ubuntu 22.04 Server hoặc CentOS Stream 9, đặt hostname có ý nghĩa (không để mặc định).
- Có tài khoản quản trị non-root với sudo; công việc hằng ngày làm bằng tài khoản đó, không dùng root.

2.2 Gia cố bảo mật (ứng với tiêu chí Bảo mật 20%)

- Tường lửa (UFW trên Ubuntu hoặc firewalld trên CentOS) bật ở chế độ mặc định chặn chiều vào; chỉ mở đúng các cổng dịch vụ cần dùng. Giải thích lý do mở từng cổng trong báo cáo.
- Gia cố SSH trong sshd_config: tắt đăng nhập root, cấu hình xác thực bằng khóa, và tối thiểu một trong hai {đổi cổng khác mặc định, giới hạn AllowUsers}. Có thể để đăng nhập bằng mật khẩu phục vụ demo nhưng báo cáo phải nêu rõ đánh đổi.
- Cài fail2ban bảo vệ SSH. Phải trình diễn được một lần ban trực tiếp (hoặc cho xem một ban gần đây trong trạng thái jail) khi demo.
- Cài auditd (hoặc tương đương) theo dõi ít nhất hai tệp nhạy cảm /etc/passwd và /etc/shadow, với dấu vết kiểm toán đọc được.
- Ghi lại một lần chạy Lynis trong báo cáo với điểm gia cố và ít nhất ba mục đã khắc phục.

2.3 Sao lưu & khôi phục (ứng với tiêu chí Sao lưu 20%)

- Sao lưu tự động dữ liệu quan trọng của hệ thống (dump CSDL và/hoặc file ứng dụng và/hoặc nội dung web), có nén và gắn nhãn thời gian.
- Chính sách lưu giữ (retention) tự động xóa bản sao lưu cũ hơn một mốc đã nêu (ví dụ 7 ngày), hiện thực trong script — không làm thủ công.
- Lịch chạy sao lưu bằng cron hoặc systemd timer, có ghi lại lịch trong báo cáo.
- Có quy trình khôi phục chạy được trực tiếp. Khi demo, nhóm sẽ hủy hoặc làm hỏng dữ liệu đang chạy rồi khôi phục từ bản sao lưu, và chứng minh dữ liệu còn nguyên vẹn.

2.4 Tự động hóa (ứng với tiêu chí Tự động hóa 15%)

- Ít nhất một script health-check kiểm tra trạng thái thực của hệ thống (dịch vụ còn chạy không, cổng có lắng nghe không, ngưỡng disk/CPU/RAM) và phản ứng — ghi log và/hoặc cảnh báo — khi có bất thường.
- Script dùng set -euo pipefail và trap trên ERR/EXIT để bắt lỗi thay vì bỏ qua thầm lặng.
- Mọi script vượt qua shellcheck không còn lỗi. Kèm output shellcheck sạch hoặc nêu các cảnh báo còn lại có lý do trong báo cáo.
- Cảnh báo hiện thực qua ít nhất một kênh: lệnh mail, email msmtp. Một lỗi mô phỏng phải thực sự kích hoạt cảnh báo khi demo.

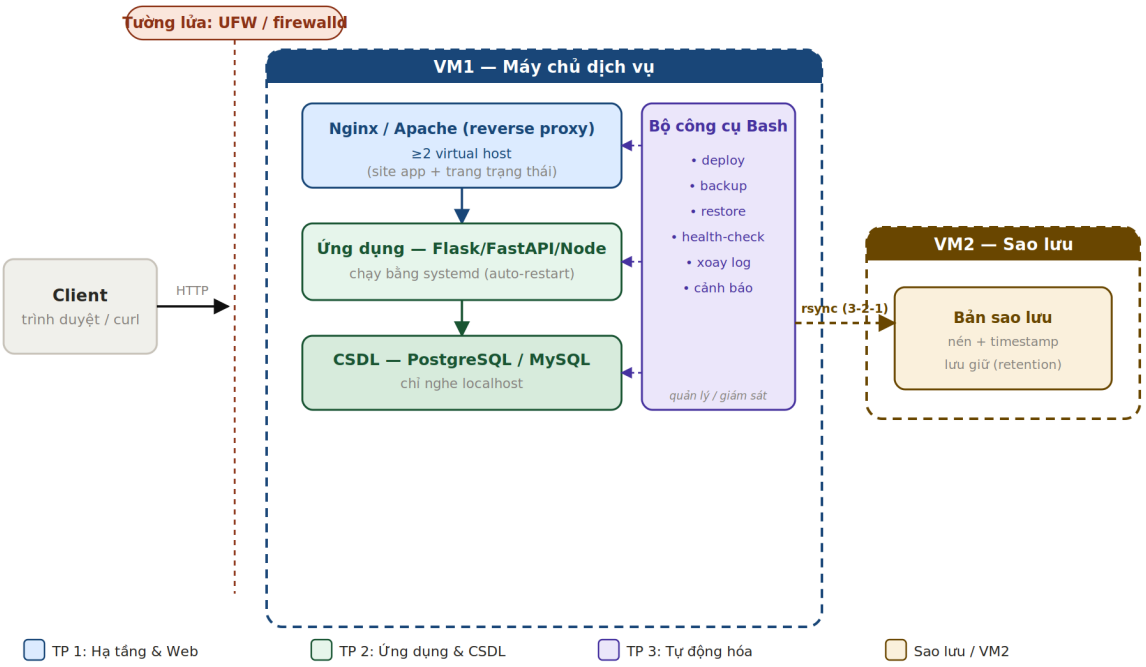
3. Dự án hợp nhất — Kiến trúc & Thành phần 1: Hạ tầng, Web & Bảo mật

> **Toàn bộ đồ án là MỘT hệ thống duy nhất**
> Xây dựng một hệ thống hợp nhất gồm ba thành phần bắt buộc: (1) Hạ tầng, Web & Bảo mật — Mục 3; (2) Ứng dụng & CSDL — Mục 4; (3) Vận hành & Tự động hóa — Mục 5.

3.1 Kiến trúc tổng thể

Luồng xử lý xuyên suốt hệ thống: trình duyệt/curl → Nginx/Apache (reverse proxy, có ≥2 virtual host) → ứng dụng chạy bằng systemd (Mục 4) → CSDL quan hệ chỉ nghe trên localhost. Toàn bộ vận hành — triển khai, sao lưu, giám sát — đi qua bộ công cụ Bash (Mục 5). Hệ thống trải trên ít nhất 2 VM: một máy dịch vụ chính và một máy nhận bản sao lưu/nhân bản.

Ba thành phần của hệ thống:



Hình 1 — Sơ đồ kiến trúc hệ thống hợp nhất và ba thành phần bắt buộc.

3.2 Yêu cầu — Hạ tầng, Web & Bảo mật

- Nginx hoặc Apache làm reverse proxy đứng trước ứng dụng ở Mục 4 (proxy_pass của Nginx, hoặc mod_proxy/ProxyPass của Apache, trỏ tới cổng cục bộ của app), chuyển tiếp đúng các header.
- Ngoài site ứng dụng, phục vụ thêm ít nhất một virtual host nữa (ví dụ trang trạng thái tĩnh hoặc site thứ hai) → tổng cộng ≥2 virtual host trên cùng một web server (Nginx hoặc Apache).
- Gia cố hệ thống đầy đủ (tường lửa = UFW hoặc firewalld tùy distro).
- Khuyến khích cho fail2ban bảo vệ cả tầng web nếu ứng dụng có endpoint dạng đăng nhập.
- Kiến trúc từ 2 VM trở lên, có sơ đồ kết nối trong báo cáo; nếu dùng VM thứ hai làm bastion, cấu hình SSH ProxyJump.

3.3 Demo phải trình diễn (phần này)

- Cả hai virtual host phản hồi, ví dụ qua curl -H "Host: ..." từ máy host hoặc VM thứ hai.
- Một lần ban fail2ban trực tiếp sau khi mô phỏng dò mật khẩu SSH.
- auditd bắt được truy cập vào /etc/passwd hoặc /etc/shadow.

4. Thành phần 2: Ứng dụng & Cơ sở dữ liệu

Tóm tắt
Một ứng dụng Python (Flask/FastAPI) hoặc Node.js thật, dùng CSDL quan hệ (PostgreSQL hoặc MySQL), chạy như dịch vụ systemd và được web server ở Mục 4 (Nginx hoặc Apache) proxy tới.

4.1 Yêu cầu — Ứng dụng & CSDL

- Một ứng dụng chạy được (Flask, FastAPI, hoặc Node.js/Express). Có thể nhỏ, nhưng phải giao tiếp với CSDL và có ít nhất một endpoint đọc và một endpoint ghi.
- Một CSDL quan hệ — PostgreSQL hoặc MySQL: tạo CSDL riêng và một user/role ứng dụng chỉ với quyền cần thiết (nguyên tắc đặc quyền tối thiểu), không dùng tài khoản quản trị của CSDL cho ứng dụng.
- CSDL chỉ nghe trên localhost (bind-address với MySQL, hoặc listen_addresses/pg_hba với PostgreSQL) — không truy cập được từ bên ngoài máy. Chứng minh bằng ss khi demo.
- Ứng dụng chạy như một dịch vụ systemd: có .service unit với Restart=on-failure, một EnvironmentFile cho bí mật (chuỗi kết nối/thông tin CSDL), và log đẩy về journald qua stdout/stderr.
- Bí mật để ngoài mã nguồn — trong EnvironmentFile với quyền hạn chế — không hard-code. Báo cáo phải cho thấy quyền của file đó.
- Sao lưu CSDL (mysqldump hoặc pg_dump) do bộ công cụ ở Mục 5 đảm nhận.

4.2 Demo phải trình diễn (phần này)

- Ứng dụng phục vụ đầu-cuối qua web server (trình duyệt hoặc curl → Nginx/Apache → app → CSDL → phản hồi).
- systemctl status cho thấy ứng dụng là dịch vụ active và enabled.
- Mô phỏng sập (kill tiến trình ứng dụng) và systemd tự khởi động lại, với sự kiện thấy được trong journalctl.
- Output ss chứng minh CSDL chỉ nghe trên 127.0.0.1.

5. Thành phần 3: Vận hành & Tự động hóa

Tóm tắt
Một bộ công cụ Bash theo dạng menu điều khiển toàn bộ vòng đời vận hành của hệ thống trên: triển khai, sao lưu & khôi phục, health-check, và xoay vòng log.

5.1 Yêu cầu — Bộ công cụ Bash

- Một menu CLI tương tác (điểm vào) điều phối tới từng công cụ và xử lý nhập sai.
- Chức năng triển khai (deploy): đưa app/site vào đúng chỗ, đặt quyền sở hữu và phân quyền đúng, rồi (khởi động lại) dịch vụ an toàn (test → reload → xác nhận, có rollback nếu reload lỗi).
- Chức năng sao lưu (backup): dump CSDL (Mục 4) + nội dung web (Mục 3), nén, gắn nhãn thời gian, lưu giữ, và rsync sang VM thứ hai.

- Chức năng khôi phục (restore): phục hồi CSDL/nội dung từ một bản sao lưu do chính bộ công cụ tạo ra.
- Chức năng health-check: CPU, disk, RAM, cổng lắng nghe, và trạng thái dịch vụ (web server, app, CSDL) so với ngưỡng cấu hình được, kèm cảnh báo khi vượt ngưỡng.
- Chức năng xoay vòng log: xoay và nén một log đã chọn, giữ N thế hệ, xóa thế hệ cũ hơn.
- Mỗi công cụ: tham số kiểu getopts khi hợp lý, set -euo pipefail, trap trên ERR, ghi log rõ đã làm gì, và có output --help. Toàn bộ vượt qua shellcheck sạch sẽ.

5.2 Demo phải trình diễn (phần này)

- Menu chạy và điều phối tới từng công cụ.
- Một lần deploy có kèm cấu hình cố tình lỗi, cơ chế reload an toàn bắt được lỗi, và tự động rollback về trạng thái tốt gần nhất.
- Một lần backup tạo file nén gắn nhãn thời gian và rsync sang VM thứ hai, cộng bước lưu giữ xóa một bản cũ.
- Hủy dữ liệu đang chạy rồi khôi phục trực tiếp từ bản sao lưu do bộ công cụ tạo ra, chứng minh toàn vẹn.
- Một lần vượt ngưỡng health-check (ví dụ dừng một dịch vụ) kích hoạt cảnh báo.
- Chạy shellcheck trực tiếp trên bộ công cụ với kết quả sạch.

6. TLS / HTTPS

6.1 Vì sao dùng tự ký, và vì sao không dùng Let’s Encrypt ở đây

Có thể quản lý TLS/HTTPS với certbot / Let’s Encrypt, nhưng cách đó không chạy được trên một VM lab cô lập — và hiểu vì sao chính là một phần của yêu cầu:

- Let’s Encrypt chỉ cấp chứng chỉ cho một tên miền công khai mà nó xác thực được qua Internet (thử thách ACME truy cập máy chủ của bạn trên cổng 80/443 từ bên ngoài).
- Một VM VirtualBox trên mạng Host-Only hoặc Internal không có tên miền công khai và không tiếp cận được từ máy chủ ACME, nên xác thực tên miền thất bại.
- Vì vậy cách đúng ở môi trường cục bộ là chứng chỉ tự ký (hoặc một CA nội bộ nhỏ do nhóm tự tạo). Báo cáo phải nêu lập luận này để được điểm thưởng — chỉ chạy lệnh là chưa đủ.

6.2 Yêu cầu

- Tạo chứng chỉ và khóa tự ký bằng openssl (hoặc CA nội bộ + chứng chỉ server cho phiên bản mạnh hơn).
- Cấu hình Nginx (hoặc Apache) phục vụ site/app qua HTTPS bằng chứng chỉ đó.
- Chuyển hướng HTTP thường sang HTTPS.
- Mở cổng 443 trên tường lửa (UFW hoặc firewalld) và xác nhận hành vi 80→443.
- Trình diễn endpoint HTTPS trực tiếp (cảnh báo tin cậy của trình duyệt là bình thường với chứng chỉ tự ký; curl -k hoặc import CA của nhóm đều chấp nhận được).

6.3 Gợi ý

Một chứng chỉ tự ký tối thiểu (chỉnh đường dẫn và subject theo hệ thống của nhóm):

```
# Tạo cặp chứng chỉ + khóa tự ký, hạn 1 năm
sudo openssl req -x509 -nodes -days 365 -newkey rsa:2048 \
  -keyout /etc/ssl/private/lab-selfsigned.key \
  -out    /etc/ssl/certs/lab-selfsigned.crt \
  -subj "/C=VN/ST=HCMC/O=HCMUS-Lab/CN=lab.local"

# Khối server Nginx (cốt lõi)
#   listen 443 ssl;
#   ssl_certificate     /etc/ssl/certs/lab-selfsigned.crt;
#   ssl_certificate_key /etc/ssl/private/lab-selfsigned.key;
# Kèm một khối HTTP trả về 301 -> https://$host$request_uri;

# Apache: SSLEngine on; SSLCertificateFile + SSLCertificateKeyFile;
#         chuyển hướng HTTP->HTTPS bằng Redirect permanent / hoặc mod_rewrite.

# CentOS Stream 9: dùng /etc/pki/tls/certs và /etc/pki/tls/private,
# mở 443 bằng: sudo firewall-cmd --add-service=https --permanent && sudo firewall-cmd --reload
```

7. Sản phẩm 1 — Báo cáo kỹ thuật

Một báo cáo kỹ thuật súc tích, nộp dạng PDF, khoảng 6–12 trang không kể phụ lục. Chất lượng và tính đúng đắn quan trọng hơn nhiều so với độ dài. Cấu trúc gợi ý:

• **Tổng quan hệ thống —** Hướng đã chọn, sơ đồ VM, chế độ mạng, và một sơ đồ hoặc mô tả rõ cách các thành phần kết nối. Kèm bảng phân công 5 thành viên.

• **Các bước xây dựng —** Những quyết định cấu hình then chốt — không phải chép lại mọi lệnh, mà đủ để người đọc tái tạo hệ thống. Tham chiếu tới các file cấu hình thật đã nộp.

• **Bảo mật —** Chính sách tường lửa và lý do mở từng cổng; lựa chọn gia cố SSH và đánh đổi; cấu hình fail2ban và auditd; điểm Lynis và ba mục đã khắc phục.

• **Sao lưu & khôi phục —** Sao lưu cái gì, bằng cách nào, lịch chạy, chính sách lưu giữ, và quy trình khôi phục chính xác — kèm bằng chứng đã kiểm thử.

• **Tự động hóa —** Từng script: mục đích, tham số, xử lý lỗi, cảnh báo. Kèm kết quả shellcheck.

Ảnh chụp là bằng chứng
Mọi khẳng định trong phần bảo mật, sao lưu và tự động hóa cần được chứng minh bằng ảnh chụp có chú thích hoặc một file cấu hình thật trong file nộp.

8. Sản phẩm 2 — Demo trực tiếp

Một buổi demo trực tiếp 12–15 phút trên chính máy ảo của nhóm. Đây là khối điểm lớn nhất (tiêu chí "Hệ thống chạy được" 30% cùng phần lớn điểm Sao lưu và Tự động hóa), nên hãy lên kịch bản và tập trước.

Kịch bản gợi ý

1. Khởi động / trình bày hệ thống đang chạy và mở trạng thái tường lửa + dịch vụ (1–2 phút).
2. Trình diễn phần lõi của hướng đã chọn chạy đầu-cuối (2–3 phút).
3. Bảo mật: kích hoạt một lần ban fail2ban; cho thấy auditd bắt được truy cập vào tệp nhạy cảm (2 phút).
4. Sao lưu & khôi phục: hủy dữ liệu đang chạy, khôi phục từ bản sao lưu tự động, chứng minh toàn vẹn (2–3 phút).
5. Tự động hóa: gây một lỗi để script health-check phát hiện và cảnh báo (1–2 phút).

Chụp snapshot trước
Chụp snapshot một trạng thái VM tốt trước khi trình bày. Nếu một bước demo trực tiếp gặp trục trặc, nhóm có thể rollback và tiếp tục thay vì mất cả buổi demo.

9. Sản phẩm 3 — Vấn đáp (Q&A)

Sau demo, giảng viên sẽ hỏi 3–5 câu kỹ thuật về hệ thống, hỏi bất kỳ thành viên nào trong nhóm. Mục tiêu là xác nhận nhóm hiểu những gì đã xây dựng chứ không chỉ làm theo hướng dẫn. Mỗi thành viên phải sẵn sàng giải thích phần mình phụ trách và nắm được tổng thể. Câu hỏi tiêu biểu:

- Vì sao mở đúng những cổng đó, và kẻ tấn công được lợi gì từ mỗi cổng?

- Trình bày từng bước điều gì xảy ra khi một yêu cầu tới web server (Nginx/Apache) và đi tới ứng dụng/CSDL.
- SSH của nhóm được gia cố ra sao, và mỗi thiết lập cụ thể ngăn chặn điều gì?
- Sao lưu chạy lúc 2 giờ sáng — nếu lúc đó đĩa đầy thì sao? Script có phát hiện không?
- Hãy khôi phục CSDL này ngay trước mặt tôi từ một bản sao lưu đã tạo trước đó.
- set -euo pipefail thay đổi gì trong script này, và ở đâu nó đã cứu nhóm?

10. Thang điểm

Đồ án chiếm 20% điểm học phần, chấm trên thang 10 điểm.

Trọng số	Tiêu chí	Bằng chứng
30%	Hệ thống chạy được	Demo trực tiếp — cả ba thành phần chạy đầu-cuối
20%	Bảo mật	UFW/firewalld, gia cố SSH, fail2ban, auditd, Lynis
20%	Sao lưu & khôi phục	Khôi phục trực tiếp phục hồi dữ liệu thật
15%	Tự động hóa	Script chạy, xử lý lỗi, cảnh báo, shellcheck
15%	Báo cáo & vấn đáp	Chất lượng báo cáo + vấn đáp

10.1 Các lỗi bị trừ điểm

- Bản sao lưu không khôi phục được khi demo: không có điểm Sao lưu, dù script sao lưu trông tốt đến đâu.
- Script không qua shellcheck (còn lỗi), hoặc bỏ qua lỗi (thiếu set -e / trap): giảm điểm Tự động hóa.
- Không giải thích được một thành phần khi vấn đáp: thành phần đó tính là "không hiểu" dù nó chạy — trừ điểm cá nhân của thành viên phụ trách.
- Nộp trễ: theo quy định nộp trễ chuẩn của chương trình.

10.2 Liêm chính học thuật

Nhóm được dùng hướng dẫn, tài liệu và trợ lý AI để học và xây dựng — điều này phản ánh thực tế nghề nghiệp. Nhưng hệ thống là của nhóm và mọi thành viên phải hiểu phần mình. Buổi vấn đáp tồn tại chính để kiểm chứng điều đó: phần không giải thích được thì không có điểm, và việc lấy hệ thống của nhóm khác nhận là của mình bị xử lý là gian lận học thuật theo quy định của Khoa.

11. Bảng kiểm yêu cầu

✓	Yêu cầu	Áp dụng	Tiêu chí
Hệ thống & lưu trữ			
☐	Cài Ubuntu 22.04 hoặc CentOS Stream 9 bản sạch; đặt hostname có ý nghĩa	Tất cả	Hệ thống
☐	Dùng tài khoản quản trị non-root (sudo) cho công việc hằng ngày	Tất cả	Bảo mật
☐	Vùng dữ liệu/sao lưu riêng mount qua /etc/fstab, tồn tại sau reboot	Tất cả	Hệ thống
☐	Kiến trúc từ 2 VM trở lên (bắt buộc với nhóm 5 người)	Tất cả	Hệ thống
Gia cố bảo mật			
☐	Tường lửa (UFW hoặc firewalld) mặc định chặn vào; chỉ mở cổng cần thiết	Tất cả	Bảo mật
☐	Gia cố SSH: tắt root, xác thực khóa, đổi cổng hoặc AllowUsers	Tất cả	Bảo mật
☐	fail2ban bảo vệ SSH; ban được kích hoạt trực tiếp	Tất cả	Bảo mật
☐	auditd theo dõi /etc/passwd và /etc/shadow; dấu vết đọc được	Tất cả	Bảo mật
☐	Ghi lại lần chạy Lynis; nêu điểm; khắc phục 3 mục	Tất cả	Bảo mật
Sao lưu & khôi phục			
☐	Sao lưu tự động: nén, gắn nhãn thời gian, có chính sách lưu giữ	Tất cả	Sao lưu
☐	Lập lịch sao lưu bằng cron hoặc systemd timer; ghi lại lịch	Tất cả	Sao lưu
☐	Đã luyện quy trình khôi phục; phục hồi dữ liệu thật trực tiếp	Tất cả	Sao lưu
Tự động hóa			
☐	Script health-check kiểm tra trạng thái thật và phản ứng (log/cảnh báo)	Tất cả	Tự động hóa
☐	Script dùng set -euo pipefail và trap trên ERR/EXIT	Tất cả	Tự động hóa
☐	Mọi script qua shellcheck (sạch, hoặc nêu cảnh báo có lý do)	Tất cả	Tự động hóa
☐	Kênh cảnh báo (mail / msmtp / Telegram) hoạt động khi mô phỏng lỗi	Tất cả	Tự động hóa
Thành phần 1 — Hạ tầng, Web & Bảo mật (bắt buộc)			
☐	Web server (Nginx/Apache) reverse proxy trước ứng dụng, chuyển tiếp header đúng	Tất cả	Hệ thống
☐	≥2 virtual host trên cùng web server (site app + ít nhất một site nữa)	Tất cả	Hệ thống
☐	Kiến trúc ≥2 VM, có sơ đồ kết nối trong báo cáo	Tất cả	Hệ thống
Thành phần 2 — Ứng dụng & CSDL (bắt buộc)			
☐	Ứng dụng (Flask/FastAPI/Node) có ít nhất một endpoint đọc và một ghi	Tất cả	Hệ thống
☐	CSDL (PostgreSQL hoặc MySQL): role đặc quyền tối thiểu; chỉ nghe localhost (ss)	Tất cả	Bảo mật

✓	Yêu cầu	Áp dụng	Tiêu chí
☐	App chạy như dịch vụ systemd: Restart=on-failure, EnvironmentFile, journald	Tất cả	Hệ thống
☐	Bí mật trong EnvironmentFile với quyền hạn chế (không hard-code)	Tất cả	Bảo mật
☐	Kill tiến trình app → systemd tự khởi động lại (thấy trong journalctl)	Tất cả	Hệ thống
Thành phần 3 — Vận hành & Tự động hóa (bắt buộc)			
☐	Menu CLI tương tác điều phối tới từng công cụ; xử lý nhập sai	Tất cả	Tự động hóa
☐	Deploy có test → reload → xác nhận an toàn và rollback khi lỗi	Tất cả	Tự động hóa
☐	Backup: dump CSDL + web, nén, gắn nhãn, lưu giữ, rsync sang VM thứ hai	Tất cả	Sao lưu
☐	Restore từ bản sao lưu do bộ công cụ tạo, phục hồi dữ liệu thật	Tất cả	Sao lưu
☐	Health-check: CPU/disk/RAM/cổng/dịch vụ so ngưỡng, có cảnh báo	Tất cả	Tự động hóa
☐	Xoay vòng log: xoay, nén, giữ N, xóa cũ hơn	Tất cả	Tự động hóa
☐	Mỗi công cụ: getopts khi hợp lý, --help, ghi log rõ; toàn bộ qua shellcheck	Tất cả	Tự động hóa
TLS/HTTPS			
☐	TLS tự ký phục vụ site/app; chuyển hướng HTTP→HTTPS; mở 443	Tất cả	Bảo mật